

25COP928

Professionalism, Ethics and Cyber Security

Cyber security and ethical hacking

Dr Parisa Derakhshan

Email p.derakhshan@lboro.ac.uk



**Loughborough
University**

#InspiringWinners since 1909

Cyber-attack, in the news every day

Cyber-attacks



Data stolen in Kensington and Chelsea cyber attack

London · 8 Jan



Cyber attack school reopening delayed to next week

Coventry & Warwickshire · 7 Jan



Lack of training could lead to future cyber attacks

Gloucestershire · 6 Jan



Cyber attack shuts school for a few days

Coventry & Warwickshire · 5 Jan



Hackers possibly took sensitive data, council says

London · 1 Jan



Rainbow Six servers back online after apparent hack

Newsbeat · 29 Dec 2025



Inquiry ongoing after UK government hacked, says minister

Politics · 19 Dec 2025



One in three using AI for emotional support and conversation, UK says

Technology · 18 Dec 2025



Loughborough University

#InspiringWinners since 1909

Examples

- **Paddington Bear Ransomware Attack** [\[Link\]](#)
- **Bybit Cryptocurrency Heist (Feb 2025)** [\[Link\]](#)
- **Cyber Threat to UK Government & Sanctions on Russian Cybercrime Networks** [\[Link\]](#)
- **Pro-Palestinian Hackers Attack Israeli Police Force** [\[Link\]](#)



Outlines

Cybersecurity definitions

Security services

Hacking in the Law

Ethical hacking

Security controls



Loughborough
University

#InspiringWinners since 1909

What is Cyber security ?

Cyber security is often referred to by different names:

- Information security
- Information assurance
- Data security
- Computer security
- IT security
- Cyber security

Cyber Security means: Technologies, processes, and mechanisms designed to protect systems, networks, and data from cyber-attacks.



Objectives of Cyber Security

Cyber security has several objectives, depending on the **type of data**, **nature of threats**, and **systems involved**. However, the main points are:

Confidentiality
prevent unauthorised
disclosure of data

Integrity
prevent unauthorised
modification of data

Availability
Prevent unauthorised use or
disruption of systems



Key Cyber Security Concepts

Asset

Anything valuable that needs protection.
E.g. network devices (routers, switches, firewalls)

Vulnerability

A weakness in an asset that can be exploited.
E.g. software bugs, weak passwords, exposed cables

Threat

Anything that can cause harm to an asset.

- **Intentional:** malware, social engineering
- **Accidental:** lost laptop
- **Environmental:** power cut



Computer misuse and hacking



Loughborough
University

#InspiringWinners since 1909

Hackers

- **White hat**
 - Ethical hackers, or penetration testers.
 - Security experts who use their skill for **ethical and legal purposes**
- **Black hat**
 - Hackers, people who violate computer security for personal gain
 - When he finds a new **“zero-day” security vulnerability**, he will sell it to criminal organizations or use it to compromise computer systems.
- **Grey hat**
 - Between white and black hats.
 - They may find vulnerabilities without permission and sometimes report them, request a fee, or make the issue public.



Hacking in the UK law

In the UK, hacking without permission is illegal and is covered by the **Computer Misuse Act 1990**.

Even activities such as **penetration testing** are only legal **with explicit permission**.

Several laws and regulations govern hacking and cyber activity, including:

- Computer Misuse Act 1990
- Serious Crime Act 2015
- Terrorism Act 2000
- GDPR (2018)
- ...and others



The Computer Misuse Act 1990

Main offences include:

- **Unauthorised access**
Accessing computer systems or data without permission.
- **Unauthorised access with intent**
Gaining access in order to commit further crimes, such as fraud.
- **Unauthorised acts causing damage**
Actions that disrupt, damage, or impair computer systems or services.



The Computer Misuse Act 1990

- The Act also makes it an offence to **make, adapt, supply, or obtain articles** for use in unlawfully gaining access to computer material or impairing the operation of a computer. Access is defined in the Act as:
 - **altering or erasing the computer programme or data**
 - **copying or moving the programme or data**
 - **using the programme or data**
 - **outputting a program or data from the computer (by display or other means)**
- **Unlawful access** occurs when a person **intentionally gains access, knows they are not entitled**, and is aware that they **do not have consent**.



Computer Misuse Act – Updates (2008)

- Clarification of the law around **hacking tools and denial-of-service software**
- Continued focus on **unauthorised access** and **unauthorised modification**, which remain central to prosecutions
- **Section 3 revised** to cover *any unauthorised act* against a computer, widening the scope of offences
- **Section 3A introduced** to criminalise making, supplying, or offering tools intended for offences under the Act
- **Section 3ZA introduced** to address attacks causing serious damage to **critical national infrastructure**



Amendments by the Police and Justice Act 2006

- **Section 35:** Unauthorised access to computer material, punishable by up to two years' imprisonment, a fine, or both.
- **Section 36:** Unauthorised acts with intent to impair the operation of a computer, punishable by up to ten years' imprisonment, a fine, or both.
- **Section 37:** Making, supplying, or obtaining articles for use in computer misuse offences, punishable by up to two years' imprisonment, a fine, or both.
- **Section 38:** Transitional and saving provisions.

[Police and Justice Act 2006](#)



Loughborough
University

#InspiringWinners since 1909

Amendments by the Serious Crime Act 2015

- **Section 41:** Unauthorised acts causing serious damage or risk (Up to 14 years' imprisonment, or life if national security or human welfare is affected)
- **Section 42:** Obtaining articles for computer misuse offences
- **Section 43:** Extends the law's territorial scope
- **Section 44:** Technical and saving provisions

[Serious Crime Act 2015](#)



Offence and penalty

Offence	Penalty
Unauthorised access to computer material	Up to 2 years in prison and/or a fine of any amount,
Unauthorised access with intent to commit or facilitate commission of further offenses	Up to a five years prison sentence and/or an unlimited fine
Unauthorized Acts with Intent to Impair Operation of a Computer (Section 3):	Up to a ten years prison sentence and/or an unlimited fine
Unauthorized Acts Causing or Creating Risk of Serious Damage (Section 3ZA):	Up to 14 years in prison; in cases involving serious damage to human welfare or national security, possible life imprisonment, a fine of any amount, or both
Making, Supplying, or Obtaining Articles for Use in Offenses (Section 3A)	Up to two years in prison, a fine of any amount, or both



Ethical Hacking and Penetration Testing

"penetration testing is a method for gaining assurance in the security of an IT system by attempting to breach some or all of that system's security, using the same tools and techniques as an adversary might."

[NCSC – Penetration testing guidance](#)

Penetration testing (also called **pen testing** or **ethical hacking**) is an **authorised security test**.

- Uses attacker techniques to find weaknesses
- **Requires explicit permission**



Threat modelling

The process of thinking like an attacker to understand how a system could be attacked and where it is most vulnerable. It considers the methods and motivations of different threat actors.

- **Cyber criminals** (organised or individual)
- **State-sponsored attackers**
- **Insider threats** (employees or contractors)
- **Hacktivists**



Test Basic

Two Approaches to Penetration Testing:

- ***Whitebox testing -***

Full information about the target is shared with the testers. This type of testing confirms the efficacy of internal vulnerability assessment and management controls by identifying the existence of known software vulnerabilities and common misconfigurations in an organisation's systems.

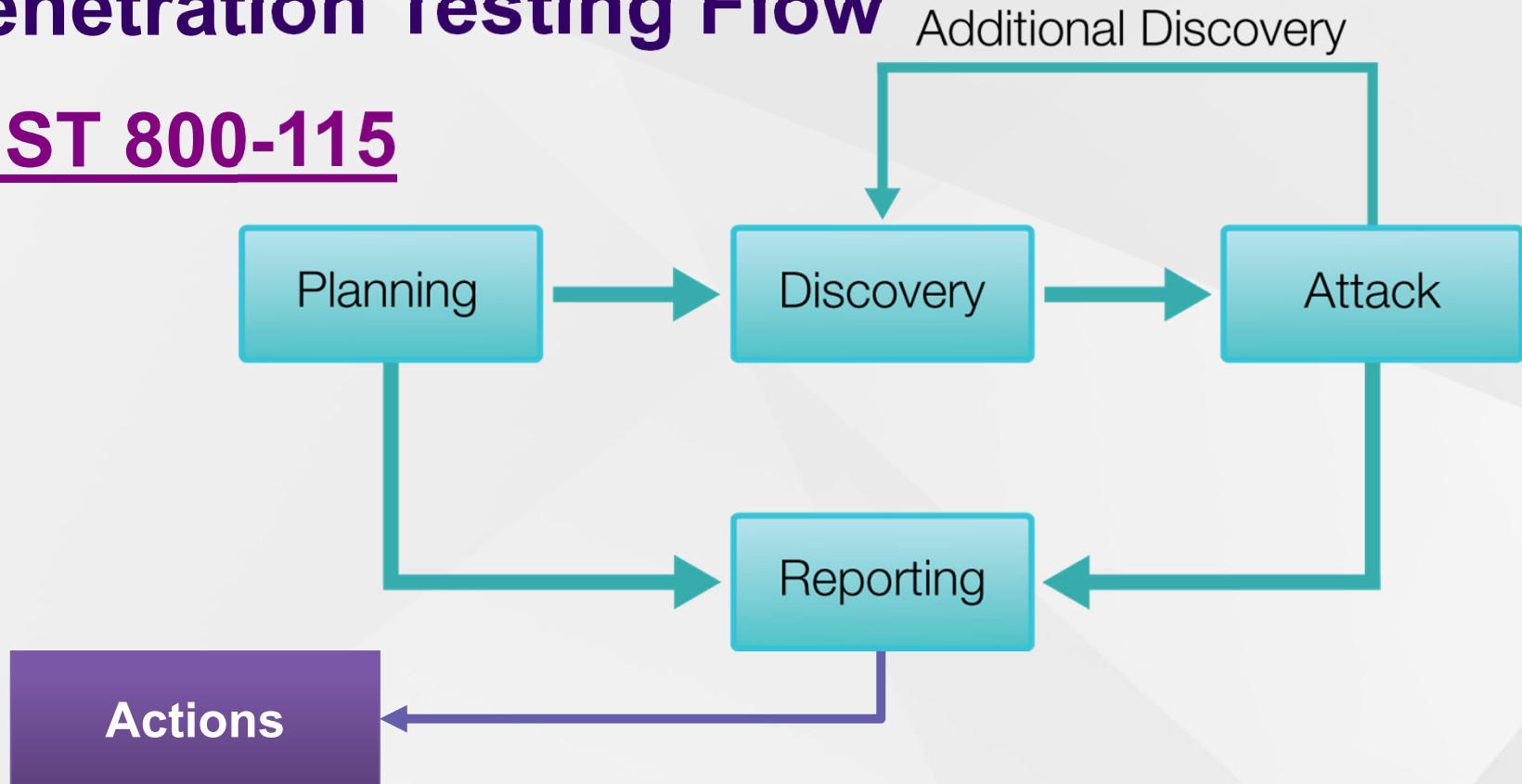
- ***Blackbox testing -***

No information is shared with the testers about the internals of the target. This type of testing is performed from an external perspective and is aimed at identifying ways to access an organisation's internal IT assets. This more accurately models the risk faced from attackers that are unknown or unaffiliated to the target organisation. However, the lack of information can also result in vulnerabilities remaining undiscovered in the time allocated for testing.



Penetration Testing Flow

- NIST 800-115



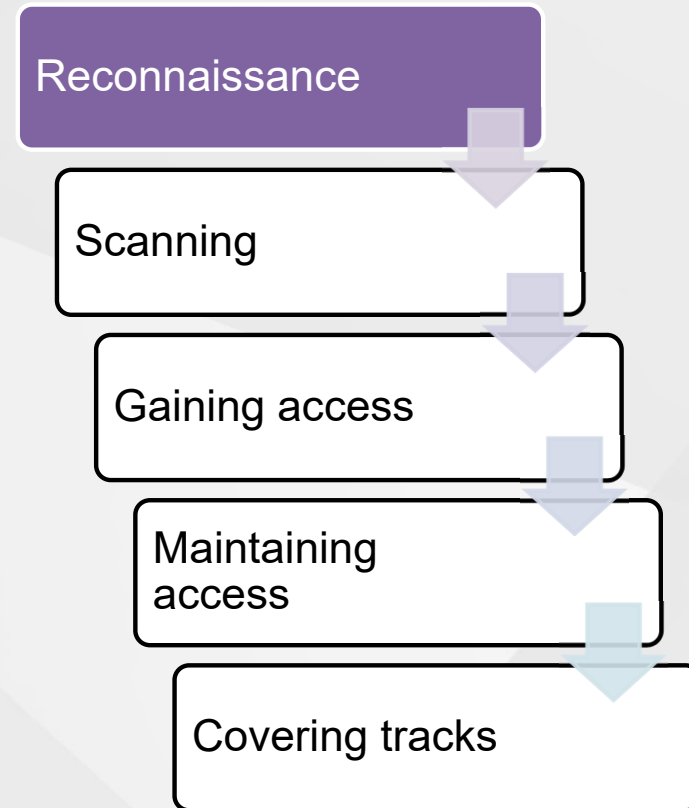
Attack steps

- Pen testing follows the attack steps.
- The objective is to make life hard for any would-be hackers at each step.



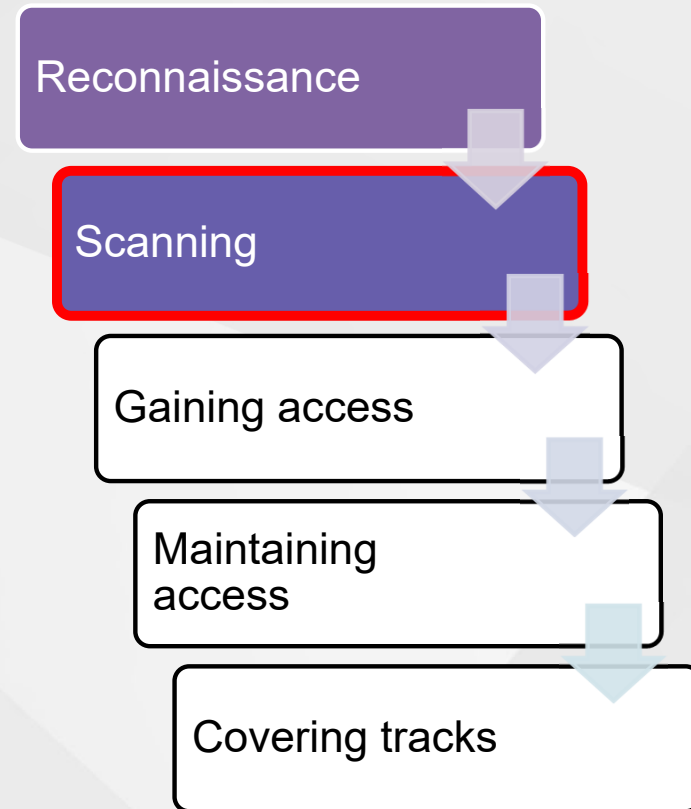
Reconnaissance

- Reconnaissance is about **information gathering**
- The term comes from the **military**, where it describes a mission to gather information about the enemy.
- Goal: Collect as much useful information as possible **without being detected**.
- If defenders detect reconnaissance early, they may be able to stop the attack before it starts.



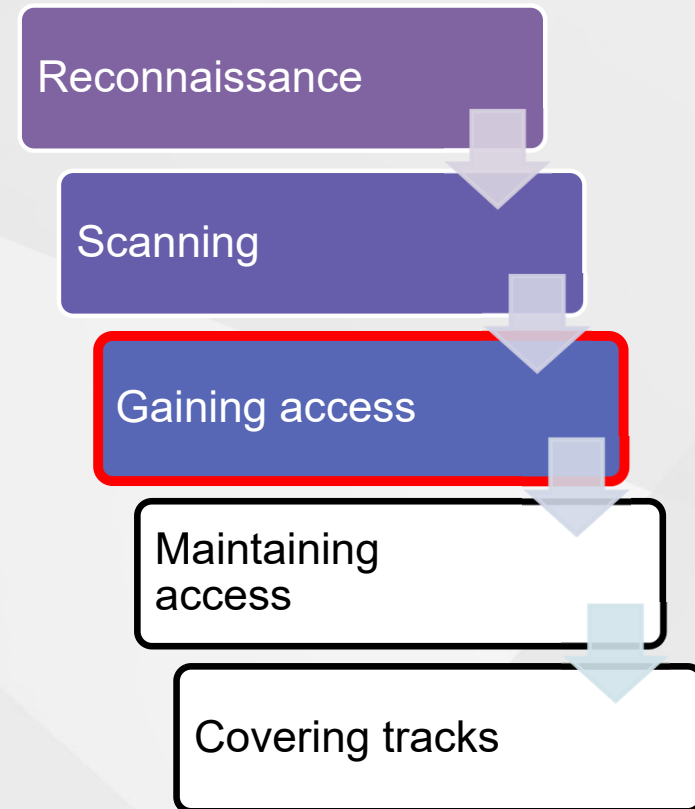
Scanning

- Attackers **test systems to find what can be attacked.**
- They look for **entry points** in networks or systems.
- **Goal:** build a **network map** and find **vulnerabilities.**
- If scanning is detected and blocked, attackers may not continue and may move to another target.



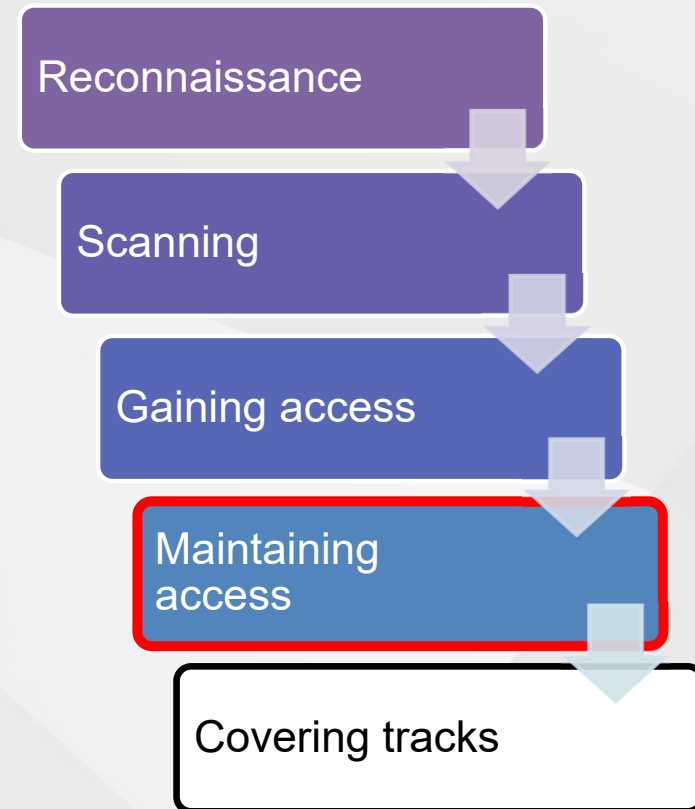
Gaining access

- **Gaining access** means using **vulnerabilities** to **break into a system**.
- The previous step focused on **finding possible entry points** in the network or target system. In this phase, attackers **launch the actual attack**.
- **Goal:** steal money, damage reputation, take revenge, perform espionage, or gain attention.



Maintaining access

- Attackers keep a way to **return to the system later**.
- They may **install malware** to collect data or control the system. Often done by creating a **backdoor** for future access.
- **Goal:** maintain **long-term access** to the system.
- If the **backdoor is detected and closed**, the attack may stop.



What covering tracks entails

- Attackers try to **erase or hide evidence of the attack**.
- They may **clear logs or hide files, processes, and activities**.
- **Malware** may be disguised as normal system files (e.g., *svchosts.exe*) or hidden deep in the system (OS kernel or BIOS).
- **Goal:** avoid detection.



Ways to maintain access and/or covering tracks

Common techniques used by attackers:

- **Backdoors:** Hidden access to a system without normal authentication.
- **OS Backdoors:** Backdoors placed in the operating system.
- **Web Backdoors:** Malicious scripts in web applications or servers.
- **Rootkits:** Tools that hide the attacker's activity.



Professional Duties and Obligations

Legal duty

Under UK Data Protection Act / GDPR, organisations must protect personal data and use appropriate security measures.

Secure development

Security should be built into systems and software during development.

Security investment

Security measures may be costly, but they protect the organisation.

Professional responsibility

The BCS Code of Conduct requires professionals to be aware of cybercrime laws.



Cyber security goals

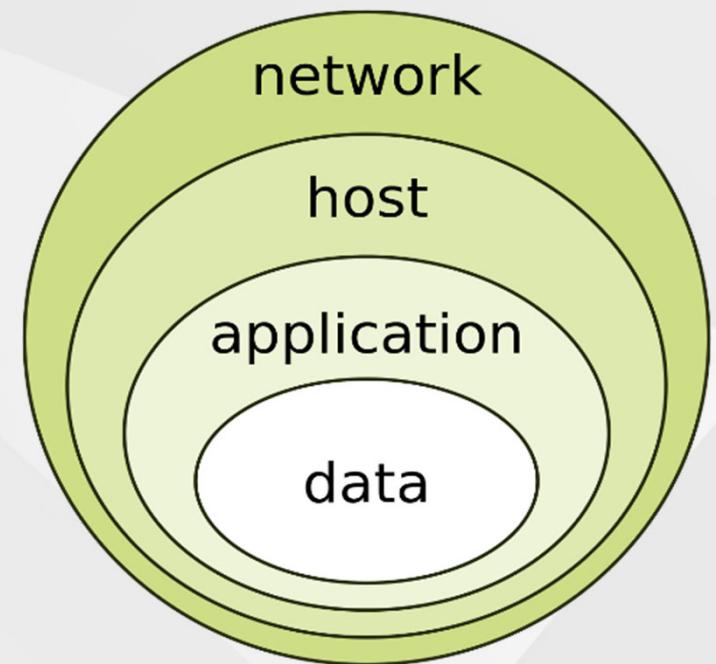


Loughborough
University

#InspiringWinners since 1909

Two Models of Information Security

- CIA – **Overall security of information**
 - Confidentiality
 - Integrity
 - Availability
- CAIN – **Important for transport**
 - Confidentiality
 - Authenticity
 - Integrity
 - Non-repudiation



Confidentiality



- Confidentiality is the need to ensure that information is disclosed only to those who are authorized to view it (SANS).



Confidentiality vs. Privacy

PRIVACY

- Do systems protect the privacy of customers/users?
- Privacy means individuals can control who accesses their personal data.

CONFIDENTIALITY

- Are there measures to keep data secure and restricted?
- Confidentiality means organisations protect customer information and use it only as agreed.

Profiling

- Profiling is the process of creating and using **user profiles** based on computerized **data analysis**.
- It discovers **patterns or correlations** in large amounts of data stored in databases.
- When these patterns are used to **identify or describe individuals**, they form a **profile**.

[https://en.wikipedia.org/wiki/Profiling_\(information_science\)](https://en.wikipedia.org/wiki/Profiling_(information_science))

